

MODULE 02 · DOMAIN 1 - DESIGN SECURE ARCHITECTURES

Network Security in the VPC

Subnets, security groups, endpoints and edge protection.

DOMAIN 1 of 4 EXAM WEIGHT 30% MODULE 2 of 22

A subnet is public only because its route table points at an **internet gateway**.
Nothing else makes it public.

How traffic leaves and enters

01

Internet gateway

Attached to the VPC. Enables two-way traffic for public subnets.

02

NAT gateway

Lets private subnets reach out. Nothing can reach in.

03

Route table

Decides which of those a subnet uses. This is where public and private is decided.

04

Security group

Stateful firewall at the instance. Allow rules only.

05

Network ACL

Stateless firewall at the subnet. Allow and deny rules.

ON THE EXAM

Outbound-only internet access for a private subnet is always a NAT gateway.

Security group or network ACL?

SECURITY GROUP

Stateful, at the instance

- Return traffic is allowed automatically
- Allow rules only. You cannot write a deny
- Evaluated as a whole; order is irrelevant
- Can reference another security group as a source

NETWORK ACL

Stateless, at the subnet

- Return traffic needs its own explicit rule
- Allow and deny rules both available
- Evaluated in numbered order, first match wins
- References CIDR ranges only, never a group

THE TIEBREAKER

Need to block one specific IP address? Only a NACL can do it. Security groups cannot deny.

Gateway endpoint or interface endpoint?

GATEWAY ENDPOINT

S3 and DynamoDB only

- A route table entry, not an ENI
- No additional charge at all
- Only reachable from inside the VPC
- Controlled with an endpoint policy

INTERFACE ENDPOINT

Nearly every other service

- An ENI with a private IP in your subnet
- Charged hourly plus per GB processed
- Reachable from on premises over VPN or Direct Connect
- Powered by AWS PrivateLink

THE TIEBREAKER

S3 or DynamoDB, and only from inside the VPC? Gateway endpoint, and it is free. Anything else needs an interface endpoint.

Protecting the edge

- ◆ **AWS WAF.** Layer 7 filtering on CloudFront, ALB, API Gateway or AppSync. SQL injection, cross-site scripting, rate limiting, geo-blocking.
- ◆ **AWS Shield Standard.** Free, automatic, on every account. Handles common layer 3 and 4 DDoS attacks.
- ◆ **AWS Shield Advanced.** Paid. Adds a response team, cost protection for scaling during an attack, and richer visibility.
- ◆ **AWS Network Firewall.** Stateful inspection for the whole VPC, including outbound domain filtering.
- ◆ **AWS Firewall Manager.** Applies WAF and firewall rules consistently across every account in the organisation.

ON THE EXAM

SQL injection means WAF. Volumetric DDoS means Shield. Consistency across accounts means Firewall Manager.

Connecting to on-premises networks

OPTION	CHARACTERISTICS	CHOOSE WHEN
Site-to-Site VPN	Encrypted over the internet, fast to set up	Speed matters, or a backup path
Direct Connect	Private line, weeks to provision	Bandwidth and predictable latency
DX with VPN backup	Private primary, encrypted failover	Resilience required
Transit Gateway	Hub for many VPCs and on-premises	More than a few VPCs
VPC peering	One-to-one, non-transitive	Two VPCs only

ON THE EXAM

Peering is not transitive. A peered to B and B to C does not let A reach C.

Access without exposure

How the exam expects you to reach private instances.

- ◆ **Systems Manager Session Manager.** Shell access with no open ports, no bastion host, no SSH keys. Logged to CloudTrail.
- ◆ **Bastion host.** The older pattern. A hardened instance in a public subnet. Still correct if the question rules out agents.
- ◆ **VPC Flow Logs.** Records accepted and rejected traffic metadata. The answer to 'why is this connection failing'.
- ◆ **Anti-pattern.** Opening SSH to 0.0.0.0/0, even temporarily.

ON THE EXAM

'Access private instances without opening inbound ports' is Session Manager, essentially every time.

Application servers run in private subnets and write large volumes of log files to an S3 bucket in the same Region. All outbound traffic currently routes through a NAT gateway.

The monthly bill shows a substantial NAT gateway data processing charge. Security requires that this traffic must not traverse the public internet.

Which solution meets the requirement at the LOWEST cost?

- ☐ A Create a gateway VPC endpoint for S3 and add it to the private subnets' route tables
- ☐ B Create an interface VPC endpoint for S3 in each private subnet
- ☐ C Move the application servers into public subnets with public IP addresses
- ☐ D Add a second NAT gateway to spread the traffic across Availability Zones

◆ PAUSE AND DECIDE

Which solution meets the requirement at the LOWEST cost?

- A** Gateway endpoint for S3
Traffic leaves the NAT gateway path entirely, stays on the AWS network, and gateway endpoints carry no charge whatsoever.
- B** Interface endpoint for S3
Technically works and keeps traffic private, but bills hourly and per GB. Strictly more expensive than the free option for the same result.
- C** Move servers to public subnets
Removes the NAT charge by exposing the servers directly to the internet. Fails the security requirement outright.
- D** Second NAT gateway
Improves availability and increases cost. Data processing charges are per GB, so a second gateway does not reduce them.

THE SIGNAL

S3 or DynamoDB traffic from a private subnet, with cost mentioned, is a gateway endpoint.

A public web application behind an Application Load Balancer has begun receiving automated traffic that attempts SQL injection against a login form. The origin addresses change constantly.

The security team also wants to limit any single client to one hundred requests every five minutes, and to block traffic from two countries where the company has no customers.

Which solution meets all three requirements?

- ☐ A Network ACLs denying the offending source IP ranges as they appear
- ☐ B AWS WAF on the load balancer with managed rules, a rate-based rule and geo-matching
- ☐ C AWS Shield Advanced subscribed on the load balancer
- ☐ D Security group rules restricting inbound traffic to known client addresses

◆ PAUSE AND DECIDE

Which solution meets all three requirements?

- A

 NACLs denying source ranges
*Operates at layer 4 and cannot read a SQL payload.
Chasing changing addresses by hand is endless work.*
- B

 WAF with managed, rate-based and geo rules
One service covers all three: injection filtering, request rate limiting, and country blocking.
- C

 Shield Advanced
*Aimed at DDoS volume, not application-layer injection.
Would not satisfy the SQL injection requirement.*
- D

 Security groups by client IP
This is a public application. There is no known client list, and security groups cannot express rate or geography.

THE SIGNAL

Three requirements, one service. When SQL injection, rate limiting and geo-blocking appear together, it is always WAF.

A three-tier application has web servers in public subnets and database servers in private subnets. The web tier scales between four and forty instances, so its addresses change constantly.

A junior engineer has configured the database security group to allow port 3306 from 0.0.0.0/0, reasoning that the subnet is private anyway. You are asked to correct this without breaking the application.

What should you configure?

- ☐ A Allow port 3306 from the CIDR range of the public subnets
- ☐ B Allow port 3306 from the web tier's security group as the source
- ☐ C Add a network ACL denying port 3306 from outside the VPC
- ☐ D Maintain a script that updates the rule with current web server IPs

◆ PAUSE AND DECIDE

What should you configure?

- A

 Allow from the subnet CIDR
A real improvement, but it permits anything in those subnets, including a compromised unrelated instance.
- B

 Allow from the web tier's security group
Follows the instances as they scale, needs no maintenance, and grants access to exactly the right set of servers.
- C

 NACL denying from outside the VPC
Leaves the wide-open security group in place. Does nothing about threats already inside the VPC.
- D

 Script that updates IPs
Solves it with permanent maintenance and a window of failure whenever scaling outpaces the script.

THE SIGNAL

Auto Scaling tier talking to another tier means security group referencing, not CIDR ranges.

A company has eighteen VPCs across three Regions and an on-premises data centre. They are currently joined by twenty-six individual VPC peering connections and two VPN tunnels. The networking team spends significant time managing route tables, and adding a nineteenth VPC would require many new connections. Some teams have complained that traffic cannot flow between certain VPC pairs.

Which solution reduces this complexity?

- A Replace the peering mesh with AWS Transit Gateway, peered across Regions
- B Add the missing peering connections to complete the mesh
- C Consolidate all workloads into a single large VPC per Region
- D Replace peering with PrivateLink endpoints between every VPC pair

◆ PAUSE AND DECIDE

Which solution reduces this complexity?

- A** Transit Gateway
One hub replaces the mesh, routing is centralised, and a new VPC needs a single attachment. Transit Gateway peering extends it across Regions.
- B** Complete the peering mesh
Connections grow with the square of the VPC count. This makes the maintenance burden worse, not better.
- C** One large VPC per Region
A vast migration that discards the isolation between workloads that separate VPCs provide.
- D** PrivateLink between every pair
PrivateLink exposes a specific service endpoint, not general network routing between VPCs. Wrong tool for the requirement.

THE SIGNAL

The complaint that some VPC pairs cannot reach each other is the non-transitivity of peering, described rather than named.

Instances in a private subnet can reach an S3 bucket and an internal API, but a request to an external payment provider times out. Instances in the public subnet reach the same provider without problems.

The private subnet's route table has a route for the VPC CIDR and a route to a gateway endpoint. The security group allows all outbound traffic.

What is the MOST likely cause?

- ☐ A The security group is blocking outbound HTTPS to the provider
- ☐ B There is no route to a NAT gateway for internet-bound traffic
- ☐ C The gateway endpoint is intercepting all outbound traffic
- ☐ D The instances need public IP addresses assigned to them

◆ PAUSE AND DECIDE

What is the MOST likely cause?

- A

 Security group blocking
The question states outbound traffic is fully allowed, and security groups are stateful so replies would return.
- B

 No route to a NAT gateway
The route table lists only the local CIDR and the gateway endpoint. Nothing carries internet-bound traffic, so it is silently dropped.
- C

 Gateway endpoint intercepting
A gateway endpoint only affects traffic destined for S3 or DynamoDB prefixes. It does not touch other destinations.
- D

 Assign public IPs
A public address in a subnet with no internet route changes nothing, and would defeat the purpose of a private subnet.

THE SIGNAL

Read route tables like a list. If no entry matches the destination, the packet goes nowhere.

A compliance auditor requires that administrators must be able to obtain a shell on production instances in private subnets, but no inbound port may be open on those instances and no SSH key material may be distributed to staff.

Every administrative session must be recorded for later review. The current setup uses a bastion host with shared SSH keys.

Which solution meets these requirements with the LEAST operational overhead?

- ☐ A Harden the bastion host and rotate the shared SSH keys weekly
- ☐ B Use Systems Manager Session Manager with session logging enabled
- ☐ C Deploy a Client VPN endpoint so administrators connect into the VPC first
- ☐ D Place the bastion behind a Network Load Balancer restricted to office IPs

◆ PAUSE AND DECIDE

Which solution meets these requirements with the LEAST operational overhead?

- A

 Harden and rotate keys
Keys are still distributed, which the requirement forbids, and weekly rotation is exactly the overhead being avoided.
- B

 Session Manager with logging
No inbound ports, no keys, and full session recording to S3 or CloudWatch Logs. Meets all three requirements directly.
- C

 Client VPN
Gets administrators onto the network but they still need a way into the instance, so ports and keys remain.
- D

 Bastion behind an NLB
Restricts who reaches the bastion but keeps both the open port on the target and the shared keys.

THE SIGNAL

No open ports, no keys, and full audit logging is the exact feature set of Session Manager.

Module 2 takeaways

- ◆ **Public subnet** means a route to an internet gateway. Nothing else.
- ◆ **Security groups are stateful and allow-only.** Only NACLs can deny a specific address.
- ◆ **S3 or DynamoDB from a private subnet** means a free gateway endpoint.
- ◆ **Tiers that scale** should reference each other's security groups, never CIDR ranges.
- ◆ **Peering is not transitive.** More than a few VPCs means Transit Gateway.

ON THE EXAM

Most network questions resolve to reading the route table carefully and asking what is stateful.